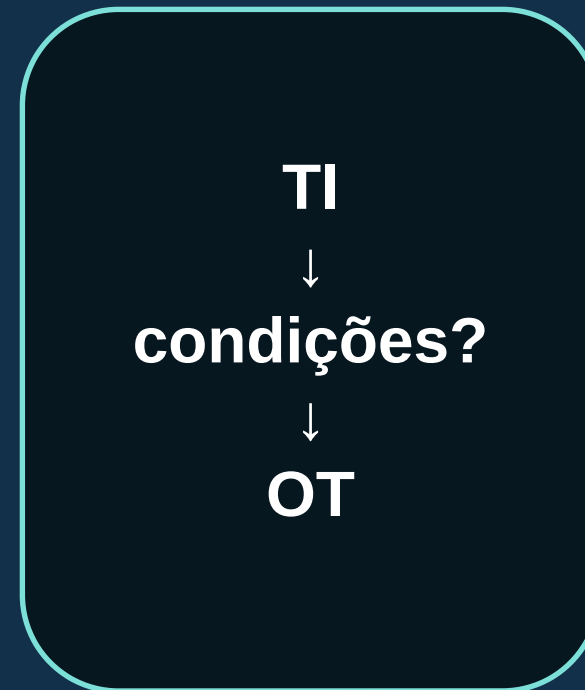


Por onde o incidente atravessa o sistema?

Na A02, inventariamos ativos e relações. Agora uma conta de suporte aparece no servidor de arquivos e uma sessão parte da engenharia em direção ao ambiente OT.

A missão não é confirmar ransomware: é descobrir o que precisa ser verdade para esses pontos formarem um caminho.



Quatro eventos, muitas explicações

O log oferece pontos no tempo. O modelo deverá mostrar se existe um caminho entre eles.

```
08:42  VPN          svc_support  login externo
08:51  FILE-01        svc_support  autenticação
09:03  FILE-01        287 arquivos renomeados
09:07  ENG-WS-01 → OT-JUMP-01  sessão
```

O QUE É FATO

Eventos registrados
Identities e destinos
Ordem temporal

O QUE AINDA É HIPÓTESE

Mesma causa
Acesso indevido
Impacto em OT

Reconstrua o funcionamento normal antes do abuso

Sem o fluxo legítimo, qualquer seta parece ataque e qualquer bloqueio parece solução.



Em cada ligação, pergunte: o que atravessa? quem autoriza? qual controle existe? o que muda se a confiança falhar?

Transforme suspeita em ameaça testável

A categoria só é útil quando aponta condição, consequência e evidência no sistema desenhado.

S

Falsificar identidade

T

Adulterar dados/comandos

R

Negar ação sem rastreabilidade

I

Divulgar além do necessário

D

Remover visão/controle

E

Obter privilégio indevido

EXEMPLO NO CENÁRIO

Se alguém reutiliza a conta compartilhada svc_support para atravessar a VPN, pode agir como fornecedor e alterar arquivos sem atribuição individual.

Validar com: origem, MFA, dono da conta e trilha de auditoria.

agente + condição + elemento + consequência + evidência

Amplie a pergunta sem perder o cenário

Cada referência entra quando precisamos explicar uma parte diferente do caminho.

STRIDE

Gerar perguntas
"que classe de
ameaça?"

CAPEC

Explicar o padrão
"quais pré-
condições?"

ATT&CK / ICS

Buscar
comportamento
"que telemetria
observar?"

KILL CHAIN

Comunicar
progressão
"onde interromper?"

No nosso caso: STRIDE formula a ameaça → CAPEC ajuda a questionar o abuso → ATT&CK orienta evidências → risco decide o tratamento.

Onde interromper sem parar a operação?

O mesmo caminho admite controles em camadas — e cada escolha protege algo enquanto pode limitar uma operação legítima.

IDENTIDADE

MFA + conta individual

reduz personificação
⚠ pode atrasar suporte

TRAVESSIA

jump host + fluxo permitido

limita movimento
⚠ exige acesso emergencial

IMPACTO

**backup + restauração
testada**

reduz consequência
⚠ não impede acesso inicial

Decida com premissa, consequência, efeito operacional e evidência de eficácia.

Novas informações mudam a decisão

Não executaremos malware: os cartões atualizam o modelo e obrigam o grupo a revisar evidência e risco.

A **BACKUP**

Último teste de restauração é desconhecido

coletar → decidir → validar

B **IDENTIDADE**

svc_support é compartilhada pelo fornecedor

coletar → decidir → validar

C **SESSÃO OT**

Estava no calendário, mas a origem diverge

coletar → decidir → validar

A cada cartão: o que mudou? qual decisão é autorizada? que evidência evita dano à operação?

Do diagrama a uma recomendação defensável

Os grupos usarão o inventário da A02 para reconstruir o sistema, testar hipóteses e justificar tratamento.

52 MINUTOS • GRUPOS DE 3–4

- 1 Fluxo normal + fronteiras
- 2 3 ameaças + 3 caminhos
- 3 Cartões + revisão do risco
- 4 Tratamento + reteste

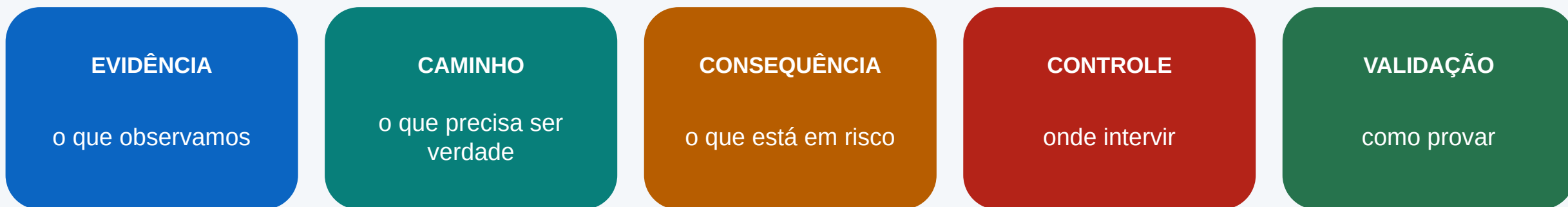
ENTREGA

Diagrama legível
3 caminhos comentados
Registro de risco
Controle e evidência de
validação

Sem malware, varredura ou
indisponibilidade

Um modelo bom muda uma decisão

Partimos de eventos correlacionados; terminamos com premissas explícitas, um ponto de interrupção e um teste.



Complete: “Interrompemos o caminho em ____ com ____; a evidência de eficácia será ____ e o risco residual é ____.”